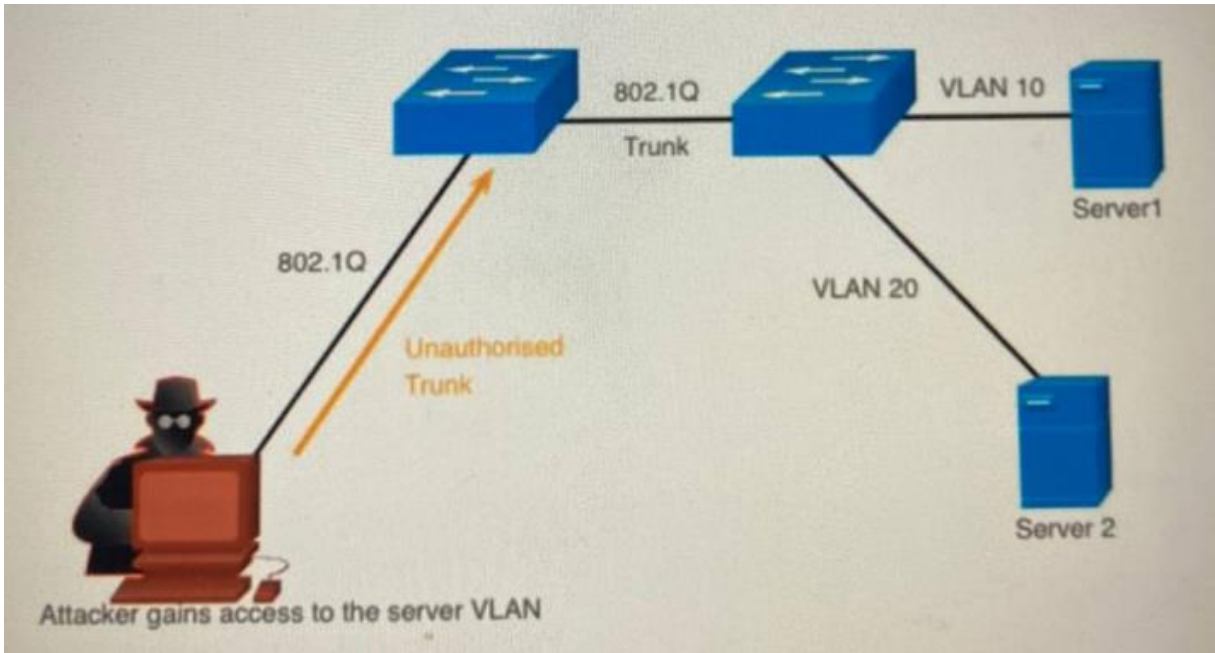


LAN Saldırıları

VLAN Atlama Saldırıları

Bir VLAN atlama saldırısı, bir yönlendiricinin yardımı olmadan bir VLAN'dan gelen trafiğin başka bir VLAN tarafından görülmesini sağlar. Temel bir VLAN atlama saldırısında, tehdit aktörü, çoğu anahtar bağlantı noktasında varsayılan olarak etkinleştirilen otomatik kanal bağlantı noktası özelliğinden (DTP) yararlanmak için bir ana bilgisayar anahtar gibi davranacak şekilde yapılandırılır.

Tehdit aktörü, ana bilgisayar bağlantı anahtarı ile devre dışı bırakmak için 802.1Q sinyalleme ve Cisco'ya özel Dinamik Kanal Protokolü (DTP) sinyalini taklit edecek şekilde yapılandırılır. Başarılı olursa, anahtar şekilde gösterildiği gibi ana bilgisayar ile bir devre bağlantısı kurar. Artık tehdit aktörü anahtardaki tüm VLAN'lara erişebilir. Tehdit aktörü, VLAN'lar arasında etkili bir şekilde atlayarak herhangi bir VLAN'a trafik gönderebilir ve alabilir.

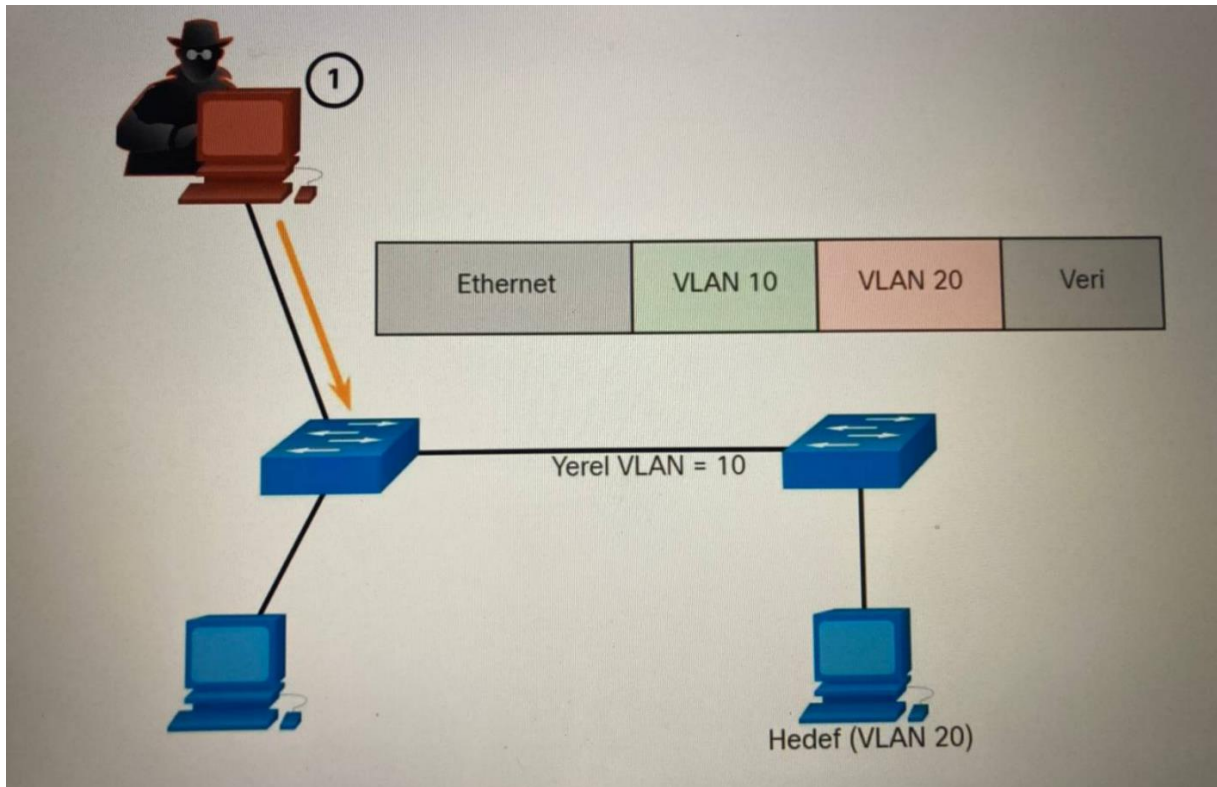


VLAN Çift Etiketleme Saldırıları

Bir tehdit aktörü, 802.1Q etiketi olan çerçevenin içine gizli bir 802.1Q etiketini yerleştirebilir. Bu etiket, çerçevenin orijinal 802.1Q etiketinin belirtmediği bir VLAN'a gitmesine izin verir.

- Adım 1: Tehdit aktörü anahtara çift etiketli bir 802.1Q çerçevesini gönderir. Dış başlıkta, tehdit bağlantı noktasının ana bağlantı noktasının yerel VLAN'ı (Native Vlan) ile aynı olan VLAN etiketi bulunur.

- Adım 2: Çerçeve, ilk 4 baytlık 802.1Q etiketine bakan ilk anahtara gelir. Anahtar, çerçevenin yerel VLAN için hedeflendiğini görür. Anahtar, VLAN etiketini çıkardıktan sonra paketi tüm yerel VLAN bağlantı noktalarından iletir. Çerçeve, yerel VLAN'ın bir parçası olduğu için yeniden etiketlenmez. Bu noktada, iç VLAN etiketi hala sağlamdır ve ilk anahtar tarafından denetlenmemiştir.
- Adım 3: Çerçeve, yerel VLAN için olması gerektiğini bilmeyen ikinci anahtara gelir. Yerel VLAN trafiği, 802.1Q protokolünde belirtildiği gibi gönderen anahtar tarafından etiketlenmez. İkinci anahtar yalnızca tehdit aktörünün eklediği iç 802.1Q etiketine bakar ve çerçevenin hedef VLAN'a yönlendirildiğini görür. İkinci anahtar, hedef için mevcut bir MAC adres tablosu girişi olup olmasına bağlı olarak çerçeveyi hedefe gönderir veya taşırır.



Bir VLAN çift etiketleme saldırısı tek yönlüdür ve yalnızca saldırgan, ana bağlantı noktasının yerel VLAN'ıyla aynı VLAN'da bulunan bir bağlantı noktasına bağlandığında çalışır. Buradaki fikir, çift etiketlemenin, saldırganın bir tür erişim kontrolü yapılandırması tarafından engellenecek bir VLAN üzerindeki ana bilgisayarlara veya sunuculara veri göndermesine izin vermesidir. Muhtemelen dönüş trafiğine de izin verilecek, böylece saldırgana normalde engellenen VLAN'daki cihazlarla iletişim kurma yeteneği sağlanacaktır.

VLAN Saldırılarını Azaltma – VLAN atlaması ve VLAN çift etiketleme saldırıları, aşağıdaki trunk güvenliği yönergeleri uygulanarak önlenabilir:

- Tüm erişim bağlantı noktalarında trunk devre dışı bırakma.
- Trunk bağlantılarında otomatik trunking işlevini devre dışı bırakın, böylece trunklar manuel olarak etkinleştirilmelidir.
- Yerel VLAN'ın yalnızca trunk bağlantıları için kullanıldığından emin olun.

DHCP Mesajları

DHCP sunucuları, istemcilere IP adresi, alt ağ maskesi, varsayılan ağ geçidi, DNS sunucuları ve daha fazlasını içeren IP yapılandırma bilgilerini dinamik olarak sağlar. İstemci ile sunucu arasındaki DHCP ileti alışverişi sırasının bir incelemesi şeklinde gösterilmiştir.



DHCP Atakları

İki tür DHCP saldırısı vardır; DHCP açlığı (**DHCP Starvation**) ve DHCP sahtekarlığı (**DHCP Spoofing Attack**). Her iki saldırı da DHCP gözetlemesi (DHCP snooping) uygulanarak azaltılır.

DHCP Starvation Attack – Bu saldırının amacı, istemcileri ağa bağlamak için bir DoS atağı oluşturmaktır. DHCP açlık saldırıları için Gobbler veya Yersinia gibi bir saldırı aracı gerekir. Bu araçlar kiralanabilir IP adreslerinin tümünü kiralamaya çalışır. Bu işi, sahte MAC adresleri ile DHCP keşif mesajları oluşturarak yaparlar.

DHCP Spoofing Attack – Bu, sahte bir DHCP sunucusu ağına bağlandığında ve yasal istemcilere yanlış IP yapılandırma parametreleri sağladığında oluşur. Sahte bir sunucu aşağıdakiler de dahil olmak üzere çeşitli yanıltıcı bilgiler sağlayabilir;

- **Wrong default gateway** – Sahte sunucu, ortadaki adam saldırısı oluşturmak için geçersiz bir ağ geçidi veya ana bilgisayarlarının IP adresini sağlar. Davetsiz misafir ağ üzerinden veri akışına müdahale ettiği için bu tamamen tespit edilemez.
- **Wrong DNS server** – Sahte sunucu, kullanıcıyı kötü amaçlı bir web sitesine yönlendiren yanlış bir DNS sunucu adresi sağlar.
- **Wrong IP address** – Sahte sunucu, DHCP istemcisine etkili bir şekilde DoS saldırısı oluşturan geçersiz bir IP adresi sağlar.

ARP Atakları

- Ana bilgisayarlar, hedef IP adresine sahip bir ana bilgisayarın MAC adresini belirlemek için ARP istekleri yayınlar. Alt ağdaki tüm ana bilgisayarlar ARP isteğini alır ve işler. ARP isteğinde eşleşen IP adresine sahip ana bilgisayar bir ARP yanıtı gönderir.
- Bir istemci gratuitous ARP Yanıtı gönderebilir. Alt ağdaki diğer ana bilgisayarlar, ARP'de bulunan MAC adresini ve IP adresini ARP tablolarında saklar.
- Saldırgan, bir anahtara sahte bir MAC adresi içeren gratuitous ARP mesajı gönderebilir ve anahtar MAC tablosunu buna göre güncelleyecektir. Tipik bir saldırıda, bir tehdit aktörü, tehdit aktörünün MAC adresi ve varsayılan ağ geçidinin IP adresi ile ağdaki diğer ana bilgisayarlara istenmeyen bir ARP yanıtları göndererek, ortadaki bir adamı (MITM) etkili bir şekilde kurar.
- İnternette ARP ortadaki adam saldırıları oluşturmak için birçok araç vardır (Ettercap).
- IPv6, Katman 2 adres çözümlemesi için ICMPv6 Komşu Bulma Protokolü'nü kullanır. IPv6, IPv6'nın sahte bir ARP yanıtını önleme yöntemine benzer şekilde Komşu Reklamı kimlik sahtekarlığını azaltmak için stratejiler içerir.
- ARP kimlik sahtekarlığı ve ARP zehirlenmesi, Dinamik ARP Denetimi (DAI-Dynamic ARP Inspection) uygulanarak azaltılır.

Address Sahtekarlığı Atakları

- IP adresi sahteciliği, bir tehdit aktörünün alt ağdaki başka bir aygıtın geçerli bir IP adresini ele geçirmesi veya rastgele bir IP adresi kullanmasıdır. IP adresi sahteciliğini azaltmak, özellikle IP'nin ait olduğu bir alt ağ içinde kullanıldığında hafifletilmesi zordur.

- MAC adresi kimlik sahtekarlığı saldırıları, tehdit aktörleri bilgisayarların MAC adreslerini, hedef bilgisayarın bilinen başka bir MAC adresiyle eşleştirecek şekilde değiştirildiğinde ortaya çıkar. Anahtar, geçerli MAC tablosu girişinin üzerine yazar ve MAC adresini yeni bağlantı noktasına atar. Daha sonra istemeden hedef ana bilgisayar için hedeflenen çerçeveleri saldıran ana bilgisayara iletir.
- Hedef ana bilgisayar trafik gönderdiğinde, anahtar MAC adresini orijinal bağlantı noktasına yeniden hizalayarak hatayı düzeltir. Anahtarın bağlantı noktası atamasını doğru durumuna döndürmesini durdurmak için tehdit aktörü, anahtara sürekli olarak çerçeve gönderecek bir program veya komut dosyası oluşturabilir, böylece anahtar yanlış veya sahte bilgileri korur. (hping, scapy)
- Katman 2'de, bir anahtarın MAC adreslerinin kaynağını doğrulamasına izin veren bir güvenlik mekanizması yoktur, bu da kimlik sahtekarlığına karşı bu kadar savunmasız kılan şeydir.
- IP ve MAC adres sahteciliği, IP Source Guard (IPSG) uygulanarak azaltılabilir.

STP Atakları

- Ağ saldırganları, kök köprüyü (root bridge) taklit ederek ve bir ağın topolojisini değiştirerek bir saldırı gerçekleştirmek için Spanning Tree Protocol (STP) manipüle edebilir. Saldırganlar daha sonra anahtarlanan etki alanı için tüm trafiği yakalayabilir.
- Bir STP manipülasyon saldırısı gerçekleştirmek için, saldırgan STP'nin yeniden hesaplamalarını zorlayacak yapılandırma ve topoloji değişiklikleri içeren STP köprü protokolü veri birimlerini (BPDU'lar) yayınlar. Saldıran bilgisayarın gönderdiği BPDU'lar kök köprü olarak seçilmek için daha küçük köprü önceliği ilan eder.
- Bu STP saldırısı, tüm erişim bağlantı noktalarına BPDU Guard uygulanarak azaltılır.

CDP Keşfi

Cisco Keşif Protokolü (CDP) tescilli bir Katman 2 bağlantı keşfi protokolüdür. Varsayılan olarak tüm Cisco cihazlarında etkindir. Ağ yöneticileri, ağ aygıtlarını yapılandırmaya ve sorun gidermeye yardımcı olması için CDP'yi kullanır. CDP bilgileri, periyodik, şifrelenmemiş, kimliği doğrulanmamış yayınlarda CDP özellikli bağlantı noktalarına gönderilir. CDP bilgileri cihazın IP adresini, IOS yazılım sürümünü, platformu, yetenekleri ve yerel VLAN'ı içerir. CDP mesajını alan aygıt CDP veri tabanını günceller.

CDP sömürsünü azaltmak için, aygıtlarda veya bağlantı noktalarında CDP kullanımını sınırlayın. Örneğin, güvenilmeyen aygıtlara bağlanan kenar bağlantı noktalarında CDP'yi devre dışı bırakın.

- Bir aygıtta CDP'yi genel olarak devre dışı bırakmak için, **no cdp run** global yapılandırma modu komutunu kullanın. CDP'yi genel olarak etkinleştirmek için **cdp run** global yapılandırma komutunu kullanın.
- Bir bağlantı noktasında CDP'yi devre dışı bırakmak için, **no cdp enable** arabirimi yapılandırma komutunu kullanın. Bir bağlantı noktasında CDP'yi etkinleştirmek için **cdp enable** arabirimi yapılandırma komutunu kullanın.